

WebPwn Advanced Pentest Report

Target: https://juiceshop.akto.io/#!/

Date: 2026-05-20 15:02 | Generated by WebPwn Senior Pentest Module

Executive Summary

This report presents the findings of an advanced automated security assessment against https://juiceshop.akto.io/#!/. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 111 security findings were recorded.

Severity	Count
CRITICAL	58
HIGH	21
MEDIUM	11
LOW	3
INFO	26

Detailed Security Findings

#1 [CRITICAL] Unauthenticated Admin Access

Location: https://juiceshop.akto.io/#!/admin

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /admin

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#2 [CRITICAL] Unauthenticated Admin Access

Location: https://juiceshop.akto.io/#!/admin/

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /admin/

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#3 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/administrator>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /administrator

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#4 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/administrator/>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /administrator/

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#5 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/wp-admin>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /wp-admin

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#6 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/wp-admin/>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /wp-admin/

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#7 [CRITICAL] Unauthenticated Admin Access

Location: https://juiceshop.akto.io/#/dashboard

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /dashboard

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#8 [CRITICAL] Unauthenticated Admin Access

Location: https://juiceshop.akto.io/#/control

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /control

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#9 [CRITICAL] Unauthenticated Admin Access

Location: https://juiceshop.akto.io/#/manager

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /manager

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#10 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/management>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /management

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#11 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/backend>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /backend

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#12 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/cpanel>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /cpanel

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#13 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#/login>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#14 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#!/signin>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /signin

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#15 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#!/auth>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /auth

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#16 [CRITICAL] Unauthenticated Admin Access

Location: <https://juiceshop.akto.io/#!/secure>

CVSS Score: 9.1

Technical Details: Admin path accessible without authentication: /secure

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict admin paths to authenticated and authorized users only.

#17 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/#!/admin>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/#/admin> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#18 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/#/administrator>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/#/administrator> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#19 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/#/dashboard>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/#/dashboard> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#20 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/#/wp-admin>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/#/wp-admin> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#21 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/#/manager>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/#/manager> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#22 [CRITICAL] Admin Dashboard — No Authentication Required

Location: <https://juiceshop.akto.io/#/cpanel>

CVSS Score: 9.8

Technical Details: Admin dashboard at <https://juiceshop.akto.io/#/cpanel> is directly accessible without login

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authentication Senior ware on all admin routes. Use IP allowlisting for admin access if possible.

#23 [CRITICAL] Secret Leakage in JS — Password

Location: <https://juiceshop.akto.io/main.js>

CVSS Score: 9.1

Technical Details: Password found in JavaScript file.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Remove secrets from client-side JS. Use server-side environment variables.

#24 [CRITICAL] XSS — Session Hijack Payload (Generated)

Location: <https://juiceshop.akto.io/#>

CVSS Score: 9.3

Technical Details: XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

#25 [CRITICAL] RCE — Remote Code Execution (Exploited)

Location: <https://juiceshop.akto.io/#>

CVSS Score: 10.0

Technical Details: Command 'id; whoami' executed. Output detected: 'root'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

#26 [CRITICAL] XSS — Session Hijack Payload (Generated)

Location: <https://juiceshop.akto.io/#/>

CVSS Score: 9.3

Technical Details: XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

#27 [CRITICAL] XSS — Session Hijack Payload (Generated)

Location: <https://juiceshop.akto.io/>

CVSS Score: 9.3

Technical Details: XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

#28 [CRITICAL] 2FA — Step Skip (Direct URL Access)

Location: <https://juiceshop.akto.io/#/dashboard>

CVSS Score: 9.1

Technical Details: Protected page '/dashboard' accessible without 2FA completion.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce 2FA completion check on ALL protected routes via Senior ware.

#29 [CRITICAL] 2FA — Cookie Bypass ('mfa_verified=true')

Location: <https://juiceshop.akto.io/#/dashboard>

CVSS Score: 9.8

Technical Details: Setting cookie mfa_verified=true bypasses 2FA entirely.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#30 [CRITICAL] CHAIN: XSS → CSRF → Account Takeover

Location: <https://juiceshop.akto.io/#>

CVSS Score: 9.8

Technical Details: XSS allows attacker to steal CSRF tokens from victim's browser DOM, then forge authenticated state-changing requests (password reset, email change) without victim's knowledge — leading to full account takeover.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP (Content-Security-Policy). Use SameSite=Strict cookies. Enforce CSRF tokens even when XSS is patched (defense in depth).

#31 [CRITICAL] CHAIN: IDOR → PII Exfiltration → Mass Account Hijack

Location: <https://juiceshop.akto.io/#/admin>

CVSS Score: 9.1

Technical Details: Insecure Direct Object References allow attackers to enumerate user IDs and access other users' data (emails, addresses, payment info). At scale, this enables mass PII exfiltration and account takeover.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization checks on every resource access. Use UUID instead of sequential IDs. Log and alert on anomalous data access patterns.

#32 [CRITICAL] CHAIN: JWT None Algorithm → Admin Privilege Escalation

Location: <https://juiceshop.akto.io/#>

CVSS Score: 9.8

Technical Details: JWT with 'alg:none' or weak HS256 secret allows forging tokens with arbitrary claims (e.g. role:admin). This bypasses all role-based access controls.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce RS256/ES256 algorithms. Reject 'none' algorithm. Validate all JWT claims server-side. Use short expiration times.

#33 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#/api/user/1>

CVSS Score: 9.1

Technical Details: '/api/user/1' returns identical content to both authenticated and unauthenticated sessions. PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#34 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/users/1>

CVSS Score: 9.1

Technical Details: '/api/users/1' returns identical content to both authenticated and unauthenticated sessions.

PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#35 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/account/1>

CVSS Score: 9.1

Technical Details: '/api/account/1' returns identical content to both authenticated and unauthenticated sessions.

PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#36 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/profile/1>

CVSS Score: 9.1

Technical Details: '/api/profile/1' returns identical content to both authenticated and unauthenticated sessions.

PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#37 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/order/1>

CVSS Score: 9.1

Technical Details: '/api/order/1' returns identical content to both authenticated and unauthenticated sessions.

PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#38 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/invoice/1>

CVSS Score: 9.1

Technical Details: '/api/invoice/1' returns identical content to both authenticated and unauthenticated sessions.

PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#39 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/payment/1>

CVSS Score: 9.1

Technical Details: '/api/payment/1' returns identical content to both authenticated and unauthenticated sessions. PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#40 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/document/1>

CVSS Score: 9.1

Technical Details: '/api/document/1' returns identical content to both authenticated and unauthenticated sessions. PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#41 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/file/1>

CVSS Score: 9.1

Technical Details: '/api/file/1' returns identical content to both authenticated and unauthenticated sessions. PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#42 [CRITICAL] IDOR — Confirmed: Unauthenticated Access to Private Resource

Location: <https://juiceshop.akto.io/#!/api/ticket/1>

CVSS Score: 9.1

Technical Details: '/api/ticket/1' returns identical content to both authenticated and unauthenticated sessions. PII fields: []

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization Senior ware on every endpoint. Verify that the requesting user owns the requested object. Return 401/403 for unauthenticated access.

#43 [CRITICAL] IDOR — Unauthorized DELETE

Location: <https://juiceshop.akto.io/#!/api/user/1>

CVSS Score: 9.1

Technical Details: HTTP DELETE on /api/user/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authorization on all HTTP methods.

#44 [CRITICAL] IDOR — Unauthorized PUT

Location: <https://juiceshop.akto.io/#!/api/user/1>

CVSS Score: 9.1

Technical Details: HTTP PUT on /api/user/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authorization on all HTTP methods.

#45 [CRITICAL] IDOR — Unauthorized PATCH

Location: <https://juiceshop.akto.io/#!/api/user/1>

CVSS Score: 9.1

Technical Details: HTTP PATCH on /api/user/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authorization on all HTTP methods.

#46 [CRITICAL] IDOR — Unauthorized DELETE

Location: <https://juiceshop.akto.io/#!/api/account/1>

CVSS Score: 9.1

Technical Details: HTTP DELETE on /api/account/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Enforce authorization on all HTTP methods.](#)

#47 [CRITICAL] IDOR — Unauthorized PUT

Location: <https://juiceshop.akto.io/#!/api/account/1>

CVSS Score: 9.1

Technical Details: HTTP PUT on /api/account/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Enforce authorization on all HTTP methods.](#)

#48 [CRITICAL] IDOR — Unauthorized PATCH

Location: <https://juiceshop.akto.io/#!/api/account/1>

CVSS Score: 9.1

Technical Details: HTTP PATCH on /api/account/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Enforce authorization on all HTTP methods.](#)

#49 [CRITICAL] IDOR — Unauthorized DELETE

Location: <https://juiceshop.akto.io/#!/api/order/1>

CVSS Score: 9.1

Technical Details: HTTP DELETE on /api/order/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

[Enforce authorization on all HTTP methods.](#)

#50 [CRITICAL] IDOR — Unauthorized PUT

Location: <https://juiceshop.akto.io/#!/api/order/1>

CVSS Score: 9.1

Technical Details: HTTP PUT on /api/order/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authorization on all HTTP methods.

#51 [CRITICAL] IDOR — Unauthorized PATCH

Location: <https://juiceshop.akto.io/#!/api/order/1>

CVSS Score: 9.1

Technical Details: HTTP PATCH on /api/order/1 succeeded without authorization.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce authorization on all HTTP methods.

#52 [HIGH] GCP Bucket

Location: <https://storage.googleapis.com/juiceshop-backup>

CVSS Score: N/A

Technical Details: GCP Bucket status: Open — <https://storage.googleapis.com/juiceshop-backup>

[!] Attacker Impact / Scenario:

Accessible backup files can expose full database dumps, source code, credentials, and configuration secrets. This is a critical data exposure risk.

[+] Strategic Remediation:

Remove all backup files from the web root. Store backups in a secure, non-public storage location with access controls.

#53 [HIGH] Missing Header: Content-Security-Policy

Location: <https://juiceshop.akto.io/#!/api/order/1>

CVSS Score: 7.5

Technical Details: CSP prevents XSS and data injection attacks by controlling allowed resource sources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#54 [HIGH] Missing Header: Strict-Transport-Security

Location: <https://juiceshop.akto.io/#>

CVSS Score: 7.5

Technical Details: HSTS forces HTTPS connections and prevents SSL-stripping attacks.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#55 [HIGH] DOM XSS Sink — setTimeout

Location: <https://juiceshop.akto.io/#/>

CVSS Score: 7.5

Technical Details: Dangerous sink 'setTimeout' received user-controllable data.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass unsanitized input to setTimeout.

#56 [HIGH] DOM XSS Sink — setInterval

Location: <https://juiceshop.akto.io/#/>

CVSS Score: 7.5

Technical Details: Dangerous sink 'setInterval' received user-controllable data.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass unsanitized input to setInterval.

#57 [HIGH] DOM XSS Sink — setTimeout

Location: <https://juiceshop.akto.io/>

CVSS Score: 7.5

Technical Details: Dangerous sink 'setTimeout' received user-controllable data.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass unsanitized input to setTimeout.

#58 [HIGH] DOM XSS Sink — setInterval

Location: <https://juiceshop.akto.io/>

CVSS Score: 7.5

Technical Details: Dangerous sink 'setInterval' received user-controllable data.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass unsanitized input to setInterval.

#59 [HIGH] Business Logic — Race Condition (Double Spend / Duplicate Redemption)

Location: <https://juiceshop.akto.io/#!/api/coupon/apply>

CVSS Score: 8.1

Technical Details: 15/15 concurrent requests to /api/coupon/apply succeeded. Race condition may allow double-spending, duplicate coupon use, or balance manipulation.

[!] Attacker Impact / Scenario:

Attackers can manipulate the application's state machine (e.g., negative quantities in cart) to steal services, purchase items for free, or cause financial loss to the business.

[+] Strategic Remediation:

Never trust client-side data. Enforce strict server-side validation for all state transitions, quantities (>0), and prices. Implement robust state-machine logic in backend controllers.

#60 [HIGH] Business Logic — Race Condition (Double Spend / Duplicate Redemption)

Location: <https://juiceshop.akto.io/#!/api/withdraw>

CVSS Score: 8.1

Technical Details: 15/15 concurrent requests to /api/withdraw succeeded. Race condition may allow double-spending, duplicate coupon use, or balance manipulation.

[!] Attacker Impact / Scenario:

Attackers can manipulate the application's state machine (e.g., negative quantities in cart) to steal services, purchase items for free, or cause financial loss to the business.

[+] Strategic Remediation:

Never trust client-side data. Enforce strict server-side validation for all state transitions, quantities (>0), and prices. Implement robust state-machine logic in backend controllers.

#61 [HIGH] Business Logic — Race Condition (Double Spend / Duplicate Redemption)

Location: <https://juiceshop.akto.io/#!/api/transfer>

CVSS Score: 8.1

Technical Details: 15/15 concurrent requests to /api/transfer succeeded. Race condition may allow double-spending, duplicate coupon use, or balance manipulation.

[!] Attacker Impact / Scenario:

Attackers can manipulate the application's state machine (e.g., negative quantities in cart) to steal services, purchase items for free, or cause financial loss to the business.

[+] Strategic Remediation:

Never trust client-side data. Enforce strict server-side validation for all state transitions, quantities (>0), and prices. Implement robust state-machine logic in backend controllers.

#62 [HIGH] Business Logic — Race Condition (Double Spend / Duplicate Redemption)

Location: <https://juiceshop.akto.io/#!/api/redeem>

CVSS Score: 8.1

Technical Details: 15/15 concurrent requests to /api/redeem succeeded. Race condition may allow double-spending, duplicate coupon use, or balance manipulation.

[!] Attacker Impact / Scenario:

Attackers can manipulate the application's state machine (e.g., negative quantities in cart) to steal services, purchase items for free, or cause financial loss to the business.

[+] Strategic Remediation:

Never trust client-side data. Enforce strict server-side validation for all state transitions, quantities (>0), and prices. Implement robust state-machine logic in backend controllers.

#63 [HIGH] 2FA — No Rate Limiting on OTP (Brute-force Possible)

Location: <https://juiceshop.akto.io/#!/>

CVSS Score: 7.5

Technical Details: Tested 7 OTP codes with no lockout or 429 response.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce max 5 attempts. Add exponential backoff and account lockout.

#64 [HIGH] 2FA — Remember-Me Cookie Forgery ('remember_me')

Location: <https://juiceshop.akto.io/#/dashboard>

CVSS Score: 7.5

Technical Details: Forged 'remember_me=1' cookie bypasses 2FA for trusted device.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#65 [HIGH] 2FA — OAuth/SSO May Bypass 2FA

Location: <https://juiceshop.akto.io/#/auth/google>

CVSS Score: 7.8

Technical Details: OAuth/SSO endpoint at '/auth/google' may log users in without 2FA. Social login commonly bypasses MFA if not explicitly enforced.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce 2FA for OAuth-authenticated users. Check MFA status post-OAuth login.

#66 [HIGH] CHAIN: CORS Misconfiguration → XSS → Session Theft

Location: <https://juiceshop.akto.io/#>

CVSS Score: 8.8

Technical Details: Permissive CORS allows malicious origins to make authenticated API requests. Combined with XSS, attacker can send victim's session cookies to a controlled server via cross-origin fetch.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict CORS to trusted origins. Do not use wildcard (*) with credentials. Set HttpOnly + Secure + SameSite on cookies.

#67 [HIGH] Web Cache Deception — Sensitive Path Cacheable

Location: <https://juiceshop.akto.io/#!/profile/fake.css>

CVSS Score: 7.5

Technical Details: Authenticated path '/profile' is accessible as '/fake.css' and may be cached. An attacker can trick authenticated users to visit this URL, caching their private data for unauthenticated retrieval.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Set Cache-Control: no-store on all authenticated responses. Configure CDN to not cache URLs matching authenticated paths. Validate request path ends with expected extension.

#68 [HIGH] Web Cache Deception — Sensitive Path Cacheable

Location: <https://juiceshop.akto.io/#!/account/fake.css>

CVSS Score: 7.5

Technical Details: Authenticated path '/account' is accessible as '/fake.css' and may be cached. An attacker can trick authenticated users to visit this URL, caching their private data for unauthenticated retrieval.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Set Cache-Control: no-store on all authenticated responses. Configure CDN to not cache URLs matching authenticated paths. Validate request path ends with expected extension.

#69 [HIGH] Web Cache Deception — Sensitive Path Cacheable

Location: <https://juiceshop.akto.io/#!/dashboard/fake.css>

CVSS Score: 7.5

Technical Details: Authenticated path '/dashboard' is accessible as '/fake.css' and may be cached. An attacker can trick authenticated users to visit this URL, caching their private data for unauthenticated retrieval.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Set Cache-Control: no-store on all authenticated responses. Configure CDN to not cache URLs matching authenticated paths. Validate request path ends with expected extension.

#70 [HIGH] Web Cache Deception — Sensitive Path Cacheable

Location: <https://juiceshop.akto.io/#!/api/user/fake.css>

CVSS Score: 7.5

Technical Details: Authenticated path '/api/user' is accessible as '/fake.css' and may be cached. An attacker can trick authenticated users to visit this URL, caching their private data for unauthenticated retrieval.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Set Cache-Control: no-store on all authenticated responses. Configure CDN to not cache URLs matching authenticated paths. Validate request path ends with expected extension.

#71 [HIGH] Web Cache Deception — Sensitive Path Cacheable

Location: <https://juiceshop.akto.io/#!/settings/fake.css>

CVSS Score: 7.5

Technical Details: Authenticated path '/settings' is accessible as '/fake.css' and may be cached. An attacker can trick authenticated users to visit this URL, caching their private data for unauthenticated retrieval.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Set Cache-Control: no-store on all authenticated responses. Configure CDN to not cache URLs matching authenticated paths. Validate request path ends with expected extension.

#72 [HIGH] SAML — Replay Attack Possible (No Assertion ID Tracking)

Location: <https://juiceshop.akto.io/#!/saml/consume>

CVSS Score: 7.5

Technical Details: The same SAMLResponse was accepted twice. SAML Assertion ID is not tracked — replay attacks possible.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Track and reject previously seen SAML Assertion IDs. Enforce NotOnOrAfter.

#73 [MEDIUM] Exposed Path: /api-docs/

Location: <https://juiceshop.akto.io/api-docs/>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#74 [MEDIUM] Exposed Path: /security.txt

Location: <https://juiceshop.akto.io/security.txt>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#75 [MEDIUM] Exposed Path: /robots.txt

Location: <https://juiceshop.akto.io/robots.txt>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#76 [MEDIUM] Exposed Path: /metrics

Location: <https://juiceshop.akto.io/metrics>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#77 [MEDIUM] Exposed Path: /.well-known

Location: <https://juiceshop.akto.io/.well-known>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#78 [MEDIUM] CORS Wildcard Origin

Location: <https://juiceshop.akto.io/#>

CVSS Score: 5.3

Technical Details: Server returns Access-Control-Allow-Origin: * — any origin can read responses.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Restrict ACAO to a specific trusted origin. Never use wildcard when credentials are involved.

#79 [MEDIUM] Cookie Missing HttpOnly: ApplicationGatewayAffinityCORS

Location: <https://juiceshop.akto.io/#>

CVSS Score: 5.4

Technical Details: Cookie 'ApplicationGatewayAffinityCORS' lacks HttpOnly flag — readable by JavaScript, enabling XSS-based session theft.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#80 [MEDIUM] Cookie Missing HttpOnly: ApplicationGatewayAffinity

Location: <https://juiceshop.akto.io/#>

CVSS Score: 5.4

Technical Details: Cookie 'ApplicationGatewayAffinity' lacks HttpOnly flag — readable by JavaScript, enabling XSS-based session theft.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#81 [MEDIUM] Cookie Missing Secure Flag: ApplicationGatewayAffinity

Location: <https://juiceshop.akto.io/#>

CVSS Score: 5.4

Technical Details: Cookie 'ApplicationGatewayAffinity' lacks Secure flag — transmitted over HTTP, vulnerable to interception.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#82 [MEDIUM] Cookie Missing SameSite: ApplicationGatewayAffinity

Location: <https://juiceshop.akto.io/#>

CVSS Score: 4.3

Technical Details: Cookie 'ApplicationGatewayAffinity' has no SameSite attribute — CSRF attacks may succeed.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#83 [MEDIUM] 2FA — Not Implemented

Location: <https://juiceshop.akto.io/#>

CVSS Score: 5.9

Technical Details: No 2FA/MFA endpoint detected.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Implement TOTP-based 2FA (FIDO2/WebAuthn/RFC 6238) for all accounts.

#84 [LOW] Missing Header: Referrer-Policy

Location: <https://juiceshop.akto.io/#>

CVSS Score: 3.1

Technical Details: Missing Referrer-Policy may leak sensitive URL information to third parties.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#85 [LOW] Sensitive Data in Cookie: ApplicationGatewayAffinityCORS

Location: https://juiceshop.akto.io/#

CVSS Score: 3.1

Technical Details: Possible base64-encoded data detected in cookie 'ApplicationGatewayAffinityCORS' value.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#86 [LOW] Sensitive Data in Cookie: ApplicationGatewayAffinity

Location: https://juiceshop.akto.io/#

CVSS Score: 3.1

Technical Details: Possible base64-encoded data detected in cookie 'ApplicationGatewayAffinity' value.

[!] Attacker Impact / Scenario:

Missing secure cookie flags allow attackers to steal session tokens via Cross-Site Scripting (XSS) or Man-in-the-Senior (MitM) attacks, leading to complete account takeover.

[+] Strategic Remediation:

Set 'HttpOnly', 'Secure', and 'SameSite=Strict' attributes on all sensitive cookies. Ensure the application enforces HTTPS strictly.

#87 [INFO] Technology Fingerprinting

Location: https://juiceshop.akto.io/#/

CVSS Score: N/A

Technical Details: Technology detected: Not disclosed

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#88 [INFO] Web Crawler

Location: <https://juiceshop.akto.io/#/>

CVSS Score: N/A

Technical Details: -

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#89 [INFO] AWS S3

Location: <http://juiceshop.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://juiceshop.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#90 [INFO] AWS S3

Location: <http://juiceshop-staging.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://juiceshop-staging.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#91 [INFO] Azure Blob

Location: <https://juiceshop.blob.core.windows.net/>

CVSS Score: N/A

Technical Details: Azure Blob status: Exists — <https://juiceshop.blob.core.windows.net/>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#92 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/juiceshoptest>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/juiceshoptest>

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#93 [INFO] Infrastructure

Location: <https://juiceshop.akto.io/#/>

CVSS Score: N/A

Technical Details: Company: 13.64.0.0/11

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#94 [INFO] IP Prefixes

Location: <https://juiceshop.akto.io/#/>

CVSS Score: N/A

Technical Details: 208.66.231.0/24, 51.140.0.0/14, 128.24.0.0/16, 199.65.40.0/24, 137.117.0.0/16, 135.130.0.0/16, 204.194.56.0/22, 2001:df0:d8::/48, 134.170.0.0/16, 135.88.0.0/16...

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#95 [INFO] Exposed Path: /api-docs

Location: <https://juiceshop.akto.io/api-docs>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#96 [INFO] Exposed Path: /media

Location: <https://juiceshop.akto.io/media>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#97 [INFO] Exposed Path: /assets

Location: <https://juiceshop.akto.io/assets>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#98 [INFO] Exposed Path: /rest

Location: <https://juiceshop.akto.io/rest>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#99 [INFO] Exposed Path: /api

Location: <https://juiceshop.akto.io/api>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#100 [INFO] Exposed Path: /profile

Location: <https://juiceshop.akto.io/profile>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#101 [INFO] Exposed Path: /api/v2/

Location: <https://juiceshop.akto.io/api/v2/>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#102 [INFO] Exposed Path: /api/v3

Location: <https://juiceshop.akto.io/api/v3>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#103 [INFO] Exposed Path: /api/

Location: <https://juiceshop.akto.io/api/>

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#104 [INFO] Exposed Path: /api/v1/

Location: https://juiceshop.akto.io/api/v1/

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#105 [INFO] Exposed Path: /api/v1

Location: https://juiceshop.akto.io/api/v1

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#106 [INFO] Exposed Path: /api/v2

Location: https://juiceshop.akto.io/api/v2

CVSS Score: 0.0

Technical Details: Server error triggered — possible misconfiguration

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#107 [INFO] Missing Header: Permissions-Policy

Location: https://juiceshop.akto.io/#

CVSS Score: 2.0

Technical Details: Missing Permissions-Policy allows access to powerful browser APIs (camera, mic, etc.).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#108 [INFO] Missing Header: Cross-Origin-Opener-Policy

Location: <https://juiceshop.akto.io/#>

CVSS Score: 2.0

Technical Details: Missing COOP allows cross-origin pages to access window references.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#109 [INFO] Missing Header: Cross-Origin-Resource-Policy

Location: <https://juiceshop.akto.io/#>

CVSS Score: 2.0

Technical Details: Missing CORP allows cross-origin pages to load this site's resources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#110 [INFO] Recon — Discovered API Endpoints in JS

Location: <https://juiceshop.akto.io/#>

CVSS Score: 0.0

Technical Details: Found 20 API endpoints via JS analysis.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Ensure all discovered endpoints require authentication.

#111 [INFO] Recon — Observed API Calls (XHR/fetch)

Location: <https://juiceshop.akto.io/#>

CVSS Score: 0.0

Technical Details: Observed 27 XHR/fetch calls during crawl.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

[Review all API calls for missing authentication.](#)
